

Part 1: reconnaissance:

- How many messages did you capture? 15 ~ 16 message
- What topics are being used? hydroficient/grandmarina/sensors/main-building
- What information is visible in each message? Normal pressure (upstream, downstream, pressure differential, flow rate, device ID, timestamp, count)
- Take a screenshot of the intercepted traffic.

The screenshot shows a Windows PowerShell window with the following content:

```
ow_rate": 40.2}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915444+00:00", "counter": 65, "pressure_upstream": 81.0, "pressure_downstream": 75.5, "flow_rate": 37.2}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915451+00:00", "counter": 66, "pressure_upstream": 80.4, "pressure_downstream": 75.8, "flow_rate": 40.5}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915457+00:00", "counter": 67, "pressure_upstream": 83.8, "pressure_downstream": 74.4, "flow_rate": 37.0}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915479+00:00", "counter": 68, "pressure_upstream": 80.9, "pressure_downstream": 75.9, "flow_rate": 39.0}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915486+00:00", "counter": 69, "pressure_upstream": 80.4, "pressure_downstream": 78.0, "flow_rate": 42.8}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915493+00:00", "counter": 70, "pressure_upstream": 81.6, "pressure_downstream": 77.4, "flow_rate": 37.5}
```

Below the PowerShell window, there is a summary of the captured data:

Count:	#69
Pressure (upstream):	80.4 PSI
Pressure (downstream):	78.0 PSI
Pressure differential:	2.4 PSI
Flow rate:	42.8 gal/min

Location:	Unknown
Device ID:	GM-HYDROLOGIC-01
Time:	2026-07-16T10:33:24.915493+00:00
Count:	#70
Pressure (upstream):	81.6 PSI
Pressure (downstream):	77.4 PSI
Pressure differential:	4.2 PSI
Flow rate:	37.5 gal/min

To the right of the summary, there is a list of published readings:

```
Published reading #55
Published reading #56
Published reading #57
Published reading #58
Published reading #59
Published reading #60
Published reading #61
Published reading #62
Published reading #63
Published reading #64
Published reading #65
Published reading #66
Published reading #67
Published reading #68
Published reading #69
```

```
Windows PowerShell
+00:00", "counter": 85, "pressure_upstream": 80.1, "pressure_downstream": 74.0, "flow_rate": 41.7}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915599
+00:00", "counter": 86, "pressure_upstream": 80.7, "pressure_downstream": 75.5, "flow_rate": 40.3}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915608
+00:00", "counter": 87, "pressure_upstream": 82.7, "pressure_downstream": 74.8, "flow_rate": 40.4}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915617
+00:00", "counter": 88, "pressure_upstream": 81.3, "pressure_downstream": 74.1, "flow_rate": 43.0}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915623
+00:00", "counter": 89, "pressure_upstream": 82.1, "pressure_downstream": 77.9, "flow_rate": 41.1}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915630
+00:00", "counter": 90, "pressure_upstream": 82.1, "pressure_downstream": 76.0, "flow_rate": 40.0}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915637
+00:00", "counter": 91, "pressure_upstream": 81.3, "pressure_downstream": 77.4, "flow_rate": 40.8}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915644
+00:00", "counter": 92, "pressure_upstream": 83.6, "pressure_downstream": 76.7, "flow_rate": 37.2}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915651
+00:00", "counter": 93, "pressure_upstream": 80.1, "pressure_downstream": 76.2, "flow_rate": 39.6}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915658
+00:00", "counter": 94, "pressure_upstream": 81.5, "pressure_downstream": 74.3, "flow_rate": 39.4}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915664
+00:00", "counter": 95, "pressure_upstream": 82.7, "pressure_downstream": 76.7, "flow_rate": 40.3}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915671
+00:00", "counter": 96, "pressure_upstream": 81.3, "pressure_downstream": 75.8, "flow_rate": 39.5}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915679
+00:00", "counter": 97, "pressure_upstream": 83.0, "pressure_downstream": 76.1, "flow_rate": 42.2}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915738
+00:00", "counter": 98, "pressure_upstream": 82.0, "pressure_downstream": 76.3, "flow_rate": 118.3}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915785
+00:00", "counter": 99, "pressure_upstream": 90.8, "pressure_downstream": 40.2, "flow_rate": 39.1}
hydroficient/grandmarina/sensors/main-building {"device_id": "GM-HYDROLOGIC-01", "timestamp": "2026-07-16T10:33:24.915828
+00:00", "counter": 100, "pressure_upstream": 82.0, "pressure_downstream": 82.0, "flow_rate": 82.0}
```

Part 2: Vulnerability Analysis:

Vulnerability	What's the risk?	Evidence from Your Pipeline	Potential Attack
No encryption	Data transmitted in plain text can be read by anyone on the network	I saw complete JSON messages including device IDs, pressure readings, and timestamps in my intercepted traffic	An attacker could learn normal sensor values to craft convincing fake readings
No authentication	Anyone can get the data and access the wifi and network.	I saw the structure of reading and how often the data were sent, normal pattern of pressure flow	An attacker could learn normal patterns from data and create the fake reading during the attack. In addition, they recognize the structure of reading and path, they utilize this data to create the fake command to shut off the system as well.
No authorization	Anyone can send the fake reading through the network since it has no authorization	I saw the pipeline message clearly, there is no authorization required when I look for the data	An attacker could send the fake reading or command to turn off the device or send normal reading, but the device was leaking. They also may make DOS attacks to disrupt the system.

No message verification	Anyone could send the data through the device since the broker didn't have recognize who sent this command/message	I saw the pipeline message didn't need to verify who sent and where to send.	An attacker can pretend the normal device to send the fake reading and command since there is no verification in the pipeline.
-------------------------	--	--	--

Part 3: Remediation Recommendations:

Based on the assessment:

1. What defenses would you add?

TLS Encryption (Port 8883)

- Encrypt all traffic between devices, broker, and dashboard
- Prevents eavesdropping and man-in-the-middle attacks
- Standard approach: Configure Mosquitto to require TLS connections

Client Authentication

- Require username/password or client certificates for all connections
- Only authorized devices and dashboards can connect
- Revoke credentials immediately if a device is compromised

Topic-Based Access Control Lists (ACLs)

- Define rules: "Device GM-HYDROLOGIC-01 can only publish to devices/readings"
- Dashboards can subscribe but not publish to sensor topics
- Prevents unauthorized publishing and limits damage from compromised devices

Message Validation

- Check timestamps – reject messages older than 60 seconds
- Track counters – reject duplicate or out-of-sequence messages
- Consider adding message signatures (HMAC) for integrity verification

2. What's most urgent to fix?

Rank	Vulnerability	Why This Priority
1	No authentication	This is the front door. Without authentication, none of the other controls matter – attackers can walk right in. Fix this first.
2	No encryption	Once we control who connects, we need to protect what they send. If we don't encrypt the data, the attacker will know the device structure and normal pattern, they make the plan to attack
3	No authorization	With authentication and encryption in place, we need to limit what authenticated users can do. Least privilege principle.
4	No message verification	This is defense in depth. Even with the above controls, we should validate messages to catch compromised devices or replay attacks.

3. What trade-offs might these defenses have?

Defense	Trade-off
TLS Encryption	Performance: Encryption data and make the device performance delay on the dashboard, since it may need 1 or 2 second to encrypt the data and send it over to the dashboard . It may cause a few second delay.
Client Authentication	Complexity: Every device needs credentials. Managing certificates for 50 devices requires a provisioning process. What happens when a certificate expires at 2 AM?
Access Control Lists	Maintenance: Rules must be updated when devices are added, moved, or removed. Complex ACL configurations can have gaps or conflicts. Testing is essential.
Message Validation	Clock Sync: Timestamp validation requires all devices to have synchronized clocks. Clock drift could cause legitimate messages to be rejected. Need NTP configuration.